

Soc Internship day 12

Assignment (Advanced)

- 1 Create one detection rule
- 2 Write a use case for any attack
- 3 Map it to MITRE ATT&CK;

(1)

1. Detection Rule

Rule Name: Multiple Failed Login Attempts Followed by Successful Login

Objective:

Detect a possible brute force attack where an attacker tries many passwords and then successfully logs in.

Log Source:

Authentication logs / SSH logs / Windows Security logs / SIEM login events

Detection Logic:

```
SELECT
    source_ip,
    username,
    COUNT(*) AS failed_attempts
FROM authentication_logs
WHERE event_status = 'failed'
AND timestamp >= NOW() - INTERVAL '10 minutes'
GROUP BY source_ip, username
HAVING COUNT(*) >= 5
```

Advanced Condition:

Trigger a high-severity alert if the same `source_ip` and `username` has a successful login within 10 minutes after 5 or more failed attempts.

```
SELECT
    source_ip,
    username,
    COUNT(CASE WHEN event_status = 'failed' THEN 1 END) AS failed_attempts,
    COUNT(CASE WHEN event_status = 'success' THEN 1 END) AS successful_logins
FROM authentication_logs
WHERE timestamp >= NOW() - INTERVAL '10 minutes'
GROUP BY source_ip, username
HAVING
    COUNT(CASE WHEN event_status = 'failed' THEN 1 END) >= 5
    AND COUNT(CASE WHEN event_status = 'success' THEN 1 END) >= 1;
```

Reason:

Multiple failed login attempts followed by a successful login may indicate that the attacker guessed the correct passwords

2. Use Case for Attack

Use Case Name: SSH Brute Force Attack

Scenario:

An attacker targets a Linux server exposed to the internet through SSH. The attacker tries multiple password combinations against the same username, such as `admin`, `root`, or `user1`.

After several failed attempts, the attacker successfully logs in using the correct password. This may allow the attacker to access the server, steal files, install malware, or create a new user account for persistence.

Example Logs:

```
May 27 10:01:11 server sshd[1201]: Failed password for admin from 203.0.113.45 port 44521 ssh2
May 27 10:01:30 server sshd[1204]: Failed password for admin from 203.0.113.45 port 44522 ssh2
May 27 10:01:52 server sshd[1208]: Failed password for admin from 203.0.113.45 port 44523 ssh2
May 27 10:02:15 server sshd[1211]: Failed password for admin from 203.0.113.45 port 44524 ssh2
May 27 10:02:39 server sshd[1215]: Failed password for admin from 203.0.113.45 port 44525 ssh2
May 27 10:03:10 server sshd[1220]: Accepted password for admin from 203.0.113.45 port 44526
ssh2
```

Why This Is Suspicious:

The same IP address attempted multiple failed logins within a short time and then successfully logged in. This pattern strongly indicates a brute force or password guessing attack.

3. MITRE ATT&CK Mapping

MITRE describes **Brute Force** as attempts to gain account access when passwords are unknown, including repeated password guessing. It also describes **Valid Accounts** as abuse of legitimate credentials to gain access.

Attack Stage	MITRE Tactic	Technique	Technique ID	Explanation
Attacker tries many passwords	Credential Access	Brute Force	T1110	The attacker attempts multiple passwords to discover valid credentials.
Attacker guesses common passwords	Credential Access	Password Guessing	T1110.001	The attacker tries common passwords against a known username.
Attacker successfully logs in	Initial Access	Valid Accounts	T1078	The attacker uses a valid username and password to access the system.
Attacker uses SSH service	Initial Access	External Remote Services	T1133	The attacker accesses the system through an exposed remote service like SSH or VPN.